Team 32 – White Team Documentation

International Cybersecurity Defense Challenge (ICDC) 2026

Iowa State University

Table of Contents

1. Public Services
2. Network Architecture
3. Firewall & Network Controls
4. Server Hardening Strategy
5. Server-by-Server Security Controls
    - Active Directory
    - Ticketing Machine
    - Management Backend
    - Admin UI
    - Public Website
    - Wazuh HIDS / SIEM
6. Backup & Recovery Strategy
7. Detection & Active Response (Wazuh)
8. Windows LOLBAS Hardening
9. TLS & Web Hardening
10. Summary of Defensive Posture

1. Public Services

All services were deployed using the **assigned public IP addresses**, without NAT or firewall virtualization.

Subdomain	IP Address	Service
ad.team32.isucdc.com	64.91.37.10	Active Directory

Subdomain	IP Address	Service
tickets.team32.isucdc.com	64.91.37.20	Ticketing Backend
mgmt.team32.isucdc.com	64.91.37.30	Management Backend
admin.team32.isucdc.com	64.91.37.40	Admin Portal
www.team32.isucdc.com	64.91.37.50	Public Web
wazuh.team32.isucdc.com	64.91.37.100	SIEM / HIDS

---

2. Network Architecture

Our architecture uses a **flat public IP layout**, with **strict host-level hardening** instead of firewall segmentation.

Design Principles:

- No NAT, no pfSense, no network-level segmentation
- Strong **host-based firewalling**
- Service isolation via:
  - Windows Firewall
  - Linux iptables / firewalld
- Centralized logging and detection using **Wazuh SIEM**

Architecture Summary:

```
[ Internet / Competition Network ]
           |
-----------------------------------------------
|   AD   | Tickets | Mgmt | Admin |  WWW   |
-----------------------------------------------
                      |
                   Wazuh
```

Security Strategy:

- Enforced **minimum exposed services**
- Implemented **zero trust between hosts**
- Host-based firewall rules only allow **strict service dependencies**

---

3. Firewall & Network Controls

Because NAT/firewalls were not deployed, **all segmentation was enforced locally per-host**.

Linux Systems:

- firewalld / iptables
- Default policy: **DROP**
- Explicit allow rules for:
  - SSH (22)
  - HTTP / HTTPS (80/443)
  - App ports (5000)
  - Wazuh agent traffic

Windows Systems:

- Windows Defender Firewall:
  - Explicit inbound allow rules only for:
    - RDP (3389)
    - Application-specific ports
  - Explicit outbound blocking for LOLBins (detailed later)

---

4. Server Hardening Strategy

Operating System Hardening:

- Disabled unused services
- Disabled legacy protocols
- Enforced strong authentication policies
- Removed default weak credentials
- Restricted administrative access

Centralized Detection:

- Wazuh HIDS agent deployed across:
  - Linux servers
  - Windows servers

Monitoring:

- Real-time alerting for:
  - SSH brute-force
  - Web authentication failures
  - SQL injection patterns
  - Privilege escalation
  - Suspicious PowerShell execution

---

5. Server-by-Server Security Controls

Active Directory

ad.team32.isucdc.com – 64.91.37.10

Hardening:

- Disabled unnecessary services
- Enforced:
  - Strong password policy

    - Account lockout policy
    - Least privilege groups
- Limited administrative logins to:
    - Domain admins only

Security Monitoring:

- Wazuh Windows agent
- Event log collection:
    - Authentication failures
    - Privilege escalation
    - Group membership changes

Ticketing Machine

tickets.team32.isucdc.com – 64.91.37.20

Controls:

- Application sandboxing
- Strict firewall rules:
    - Only allow port **5000 inbound**
    - RDP limited to IT admins
- Wazuh monitoring:
    - Web attacks
    - Forged ticket attempts
    - Authentication anomalies

Management Backend

mgmt.team32.isucdc.com – 64.91.37.30

Hardening:

- firewalld policy:
  - Default deny
  - Allow only:
    - SSH 22
    - HTTP 5000
- Removed unused packages
- Hardened SSH:
  - No root login
  - Key-based authentication preferred

Monitoring:

- Wazuh:
  - SQL injection detection
  - Command injection detection
  - File integrity monitoring

Admin UI

admin.team32.isucdc.com – 64.91.37.40

Controls:

- Windows firewall:
  - Allow:
    - HTTP 80
    - RDP 3389
- Hardened IIS & backend services
- Wazuh:

- Login brute-force
- Privilege escalation detection

Public Website

www.team32.isucdc.com – 64.91.37.50

Web Hardening:

- Nginx reverse proxy
- HTTPS enforced via **self-signed certificates**
- Redirect all HTTP → HTTPS
- Application moved to **port 5000**, protected behind Nginx

TLS Configuration:

- TLS 1.2 / 1.3 only
- Disabled legacy ciphers
- HTTP → HTTPS forced redirection

⚠️ **Note:**

Service scanner reports partial scoring due to custom port handling, but encryption and authentication protections remain fully enforced.

Wazuh SIEM / HIDS

wazuh.team32.isucdc.com – 64.91.37.100

Components:

- Wazuh Manager
- File Integrity Monitoring (FIM)
- Active Response Engine
- Log Aggregation

Detection Coverage:

- SSH brute-force
- Web brute-force
- SQL injection patterns
- Suspicious command execution
- Privilege escalation attempts

---

6. Backup & Recovery Strategy

We implemented **full centralized backups** using enterprise-grade open-source tooling.

Windows Backup – UrBackup

Backup Server: `64.91.37.222`

Features:

- Full system image backups
- File-level restore
- Scheduled backups
- Bare-metal restore capability

Protected Hosts:

- Active Directory
- Admin UI
- Ticketing Machine

Linux Backup – Restic

Backup Server: `64.91.37.5`

Features:

- Encrypted incremental backups
- Fast restore
- Deduplication
- Snapshot versioning

Protected Hosts:

- Management Backend
- Public Web Server
- Wazuh SIEM

---

7. Detection & Active Response (Wazuh)

We implemented **automated incident response using Wazuh Active Response**.

Automated Blocks:

Attack Type	Action
SSH brute-force	Auto firewall block
Web brute-force	Auto IP ban
SQL injection attempts	Auto IP ban
Excessive login failures	Auto block

Benefit:

- Stops attacks **in real time**
- Prevents lateral movement
- Limits attacker dwell time

---

8. Windows LOLBAS Binary Hardening

Objective:

Prevent attackers from abusing **Living-Off-The-Land Binaries (LOLBins)** for payload execution.

Technical Controls:

We applied **ACL restrictions** on high-risk Windows binaries:

- bitsadmin.exe
- certutil.exe
- mshta.exe
- wmic.exe
- powershell.exe (restricted mode)

Enforcement:

- Deny **Read & Execute** for:
  - `Authenticated Users`
- Retain **full permissions for Administrators**

Security Impact:

- Prevents:
  - Payload downloads
  - In-memory execution
  - Lateral movement
- Maintains:
  - Full administrator functionality
  - Competition compliance

---

9. TLS & Web Hardening

HTTPS Enforcement:

- Nginx configured to:
  - Redirect HTTP → HTTPS
  - Enforce strong cipher suites
  - Disable legacy SSL versions

Security Benefits:

- Prevents:
  - Credential sniffing
  - MITM attacks
  - Session hijacking